

⚠ **Security Warning:** Work in an isolated environment (virtual machine or container). Never open unknown files on your primary machine.

Challenge Description

Every file gets a flag.

The SOC analyst saw one image being sent back and forth between two people. They decided to investigate and found out that there was more than what meets the eye.

Tools Used

- `file` – Determine file type
 - `strings` – Extract printable character sequences
 - `exiftool` – Read metadata
 - `binwalk` – Detect and extract embedded files
 - `ls` – List directory contents
-

Complete Solution

Step 1: Download the Image

Download the image named `flag.png` from the challenge page.



At first glance, this appears to be a simple PNG image.

Step 2: Basic File Inspection

Verify the file type and understand its structure:

```
file flag.png
```

Expected output:

```
flag.png: PNG image data, 512 x 504, 8-bit/color RGBA, non-interlaced
```

The file is a valid PNG image.

Step 3: Search for Visible Text

Sometimes flags are hidden directly in the text strings of a file. Let's check:

```
strings flag.png | grep -i "picoCTF\|secret"
```

Output:

```
secret/UT
secret/flag.pngUT
secret/UT
secret/flag.pngUT
```

Interesting! The word "secret" appears, suggesting there might be a hidden archive inside the image.

Step 4: Inspect Metadata

Examine the image metadata for any anomalies:

```
exiftool flag.png
```

Expected output:

ExifTool Version Number	: 12.76
File Name	: flag.png
Directory	: .
File Size	: 43 kB
File Modification Date/Time	: 2026:05:09 15:54:14+01:00
File Access Date/Time	: 2026:05:09 15:54:14+01:00
File Inode Change Date/Time	: 2026:05:09 15:54:51+01:00
File Permissions	: -rwxrwxrwx
File Type	: PNG
File Type Extension	: png
MIME Type	: image/png
Image Width	: 512
Image Height	: 504
Bit Depth	: 8
Color Type	: RGB with Alpha
Compression	: Deflate/Inflate
Filter	: Adaptive
Interlace	: Noninterlaced
Warning	: [minor] Trailer data after PNG IEND chunk

Image Size : 512x504
Megapixels : 0.258

Key finding: The `Warning` line indicates **“Trailer data after PNG IEND chunk”**. This is unusual and suggests that there is additional data appended after the end of the PNG image — a classic sign of file steganography.

Step 5: Analyze with Binwalk

`binwalk` is a powerful tool that scans for embedded files and known file signatures. Let’s run it:

```
binwalk flag.png
```

Output:

DECIMAL	HEXADECIMAL	DESCRIPTION
0	0x0	PNG image, 512 x 504, 8-bit/color RGBA, non-interlaced
41	0x29	Zlib compressed data, compressed
39739	0x9B3B	Zip archive data, at least v1.0 to extract, name: secret/
39804	0x9B7C	Zip archive data, at least v2.0 to extract, compressed size: 2997, uncompressed size: 3152, name: secret/flag.png
43036	0xA81C	End of Zip archive, footer length: 22

The scan reveals a **ZIP archive** embedded in the PNG file, containing a folder named `secret/` with another `flag.png` inside.

Step 6: Extract the Hidden Files

Use `binwalk` with the `-e` (extract) option to automatically extract all embedded files:

```
binwalk -e flag.png
```

Output:

DECIMAL	HEXADECIMAL	DESCRIPTION
---------	-------------	-------------

0	0x0	PNG image, 512 x 504, 8-bit/color RGBA, non-interlaced
41	0x29	Zlib compressed data, compressed
39739	0x9B3B	Zip archive data, at least v1.0 to extract, name: secret/
39804	0x9B7C	Zip archive data, at least v2.0 to extract, compressed size: 2997, uncompressed size: 3152, name: secret/flag.png
43036	0xA81C	End of Zip archive, footer length: 22

Binwalk creates a new directory called `_flag.png.extracted` containing the extracted files.

Step 7: Explore the Extracted Files

List the contents of the extracted directory:

```
ls _flag.png.extracted
```

Output:

```
secret
```

Navigate into the `secret` folder:

```
ls _flag.png.extracted/secret
```

Output:

```
flag.png
```

Step 8: View the Hidden Flag

Open the newly extracted `flag.png` :

```
xdg-open _flag.png.extracted/secret/flag.png
```

Alternatively (on macOS): `open _flag.png.extracted/secret/flag.png`

Alternatively (on Windows): `start _flag.png.extracted/secret/flag.png`

This second image contains the actual flag!

Final Result

picoCTF{<REDACTED>}

Note: The actual flag is redacted here. In the real challenge, the extracted image will display the complete flag.

Key Concepts

- **File Steganography:** Hiding one file inside another. Here, a ZIP archive was appended to a PNG image.
- **PNG Structure:** A PNG file ends with an `IEND` chunk. Any data after this chunk is ignored by image viewers but can be detected by tools like `binwalk` . |
- **Binwalk:** A forensic tool that scans for embedded files and known file signatures (ZIP, JPEG, ELF, etc.).
- **File Carving:** The process of extracting embedded files from a larger data stream based on their file headers and footers.
- **Metadata Analysis:** Using `exiftool` to detect anomalies (e.g., "Trailer data after PNG IEND chunk") that indicate hidden content.